

NIST Special Publication 800-92, "Guide to Computer Security Log Management", establishes guidelines and recommendations for securing and managing sensitive log data. The publication was prepared by Karen Kent and Murugiah Souppaya of the National Institute of Science and Technology and published under the SP 800-Series; a repository of best practices for the InfoSec community. Log management is essential to ensuring that computer security records are stored in sufficient detail for an appropriate period of time.

Background

Effective security event logging and log analysis is a critical component of any comprehensive security program within an organization. It is used to monitor system, network and application activity. It serves as a deterrent for unauthorized activity, as well as provides a means to detect and analyze an attack in order to allow the organization to mitigate or prevent similar attacks in the future. However, security professionals have a significant challenge to determine what events must be logged, where and how long to retain those logs, and how to analyze the enormous amount of information that can be generated. A deficiency in any of these areas can cause an organization to miss signs of unauthorized activity, intrusion, and loss of data, which creates additional risk.

Scope

NIST SP 800-92 provides a high-level overview and guidance for the planning, development and implementation of an effective security log management strategy. The intended audience for this publication include the general information security (InfoSec) community involved in incident response, system/application/network administration and managers.

NIST SP 800-92 defines a log management infrastructure as having 4 major functions:

General - log parsing, event filtering and event aggregation;

Log Storage - rotation, archival, compression, reduction, normalization, integrity checking;

Log Analysis - event correlation, viewing and reporting;

Disposal - clearing;

NIST SP 800-92 address the following security log management challenges:

Log volume exceeding the rate of analysis;

Ensuring immutability during storage and transmission;

Inconsistent vendor log formats;

Importance of a consistent review schedule;

Retention issues involving purging, long-term storage, and cost;

NIST SP 800-92 makes the following recommendations for security log management:

Establish policies and procedures for log management;

Prioritize log management appropriately throughout the organization;

Create and maintain a log management infrastructure;

Provide proper support for all staff with log management responsibilities;

Establish standard log management operational processes;

Compliance

The following federal regulations require the proper handling and storage of sensitive log data:

HIPAA (Health Insurance Portability and Accountability Act of 1996). Requires the mandatory safeguard of personal health information.

SOX (Sarbanes-Oxley Act of 2002). Requires the mandatory record keeping of financial and IT log related data.

GLBA (Gramm-Leach-Bliley Act). Requires mandatory PII (Personal Identifiable Information) data protection.

PCI DSS (Payment Card Industry Data Security Standard). Requires the mandatory protection of consumer credit card information including storage and transmission.

FISMA (Federal Information Security Management Act of 2002). Stipulates federal requirements for managing government network systems and data. Log management guidelines include the generation, review, protection and retention of audit records, as well as the actions to be taken because of audit failure.

References

External links

NIST Special Publication 800-92